Аудит безопасности и стабильности

Технический обзор безопасности и надёжности неофициального сервиса `rasp.ifmagic.ru`: адаптера личного расписания ИТМО, который читает данные из `my.itmo.ru` и отдаёт их подпиской ICS и read-only CalDAV.

1. Область и метод

Что проверялось. Модель доступа «секретная ссылка = аккаунт» (выпуск, хранение, отзыв и перевыпуск ссылки), вход в ИТМО (учётные данные и токены сессии, промежуточные шаги двухфакторного входа), сессии браузера и cookie, защита от подделки межсайтовых запросов, ограничение частоты и защита от перебора, работа с секретами и персональными данными, шифрование и логирование, транспорт и заголовки периметра, устойчивость синхронизации расписания и обработки сбоев источника, совместимость с календарными клиентами (ICS и CalDAV), эксплуатационные аспекты (наблюдаемость, резервное копирование, ограничения ресурсов, жизненный цикл процессов), зависимости и цепочка поставки, доступность интерфейса, в том числе без JavaScript.

Чем проверялось. Чтение исходного кода и документации, локальные прогоны `go build`, `go vet` и `go test` (включая интеграционные тесты против базы данных и прогон с детектором гонок), сканер уязвимостей зависимостей и стандартной библиотеки (`govulncheck`), проверка целостности модулей (`go mod verify`), а также безопасные наблюдения на живом сервисе: заголовки, TLS, cookie, лимиты, обработка ошибок. Живые проверки выполнялись только чтением, без эксплуатации уязвимостей и без реальных учётных данных.

Границы. Обзор носит характер **внутренней самооценки команды проекта (self-assessment), а не независимого пентеста**. Вне области: конфигурация внешнего прокси и периметра, операционная система и сетевые правила сервера, сторонние сервисы (вход ИТМО, источник расписания), а также поведение реальных календарных клиентов. Точные значения переменных окружения живого сервера и фактические журналы периметра не сверялись. Всё, что не удалось подтвердить кодом или запуском, отмечено в разделе остаточных рисков.

Статусы. Все находки на момент публикации **закрыты**: либо исправлены, либо осознанно приняты как риск с компенсирующими мерами. Открытых пунктов нет. В таблицах ниже сохранена оценка критичности (Critical/High/Medium/Low) как историческая метка серьёзности; она не означает, что пункт открыт.

2. Общая оценка

Сервис спроектирован аккуратно и зрело. **Критических и высоких уязвимостей в приложении не найдено.** Секрет ссылки и сессии хранятся только в виде необратимых хэшей (`sha256`), токены ИТМО и промежуточное состояние двухфакторного входа шифруются `AES-256-GCM`, вход защищён от перебора и подделки запросов, сервис работает строго в режиме чтения, база данных недоступна извне, контейнер запускается от непривилегированного пользователя на минимальном образе.

Основные риски носили **периметровый и эксплуатационный характер**, а не кодовый. Они закрыты: часть - исправлениями, часть - принятием остаточного риска с компенсирующими мерами.

3. Что было устроено хорошо

Ещё до правок по итогам проверок в сервисе были реализованы сильные базовые решения:

- **Секретная ссылка с высокой энтропией.** Ссылка содержит случайный идентификатор (`UUIDv4` , `crypto/rand` , около 122 бит), который практически невозможно угадать; в базе хранится только его `sha256` .
- **Отсутствие хранения пароля.** Пароль ИТМО используется только в момент входа и не сохраняется; дальнейшая работа идёт с зашифрованными токенами.
- **Строгий режим чтения.** Сервис только читает расписание из личного кабинета ИТМО и не выполняет там изменений.
- **Минимум зависимостей.** Сервис построен на стандартной библиотеке и небольшом наборе проверенных библиотек.
- **Однородные ответы об ошибках.** Несуществующие и отозванные ссылки обрабатываются одинаково, без следов стека и утечки деталей.
- **Изоляция базы данных.** База не опубликована наружу и доступна только сервису.
- **Ужесточённый контейнер.** Приложение работает от непривилегированного пользователя на урезанном образе.
- **Параметризованный SQL.** Все обращения к базе параметризованы; конкатенации пользовательских данных нет.
- **Постоянное сравнение токенов CSRF.** Проверка токена защиты от подделки запросов выполняется сравнением за постоянное время.
- **Атомарное резервирование задач синхронизации.** Аккаунты клеймятся через `FOR UPDATE SKIP LOCKED` с бронью, поэтому один аккаунт не обрабатывается дважды.
- **Идемпотентные миграции.** Изменения схемы применяются идемпотентно и защищены от одновременного запуска.
- **Корректный ICS и условные запросы.** Экранирование и складывание строк по RFC 5545; `ETag` / `304` / `Range` через `http.ServeContent` .
- **Безопасная работа кэшей.** Файлы кэша не содержат секрета, доступ к каталогу ограничен правами файловой системы.

4. Реестр находок

Ниже - находки, сгруппированные по областям. Столбец «Что сделано» описывает исправление или принятую компенсирующую меру; пороги, формулы и пошаговые алгоритмы намеренно не приводятся.

4.1 Периметр и транспорт

Область	Severity	Что было	Что сделано	Статус
Редирект на HTTPS	High	`http://rasp.ifmagic.ru` отдавал страницу по открытому HTTP без перенаправления; секрет ссылки и cookie могли уйти в открытом виде	На периметре включён постоянный 301-редирект `http -> https` для хоста сервиса	Исправлено
HSTS	High	Заголовок `Strict-Transport-Security` не выставлялся ни приложением, ни периметром; возможен SSL-strip при том, что ссылка является bearer-credential	Строгий режим HSTS осознанно не включён на текущем периметре (риск задеть соседние хосты); компенсирующая мера - обязательный HTTPS-редирект	Принято, закрыто

Область	Severity	Что было	Что сделано	Статус
Публичные пробы	Info	`/healthz` и `/readyz` доступны без аутентификации; `/readyz` косвенно отражает состояние базы	Принято: пробы нужны маршрутизации и раскрывают минимум информации	Принято, закрыто
Журналы периметра	Info	Access-логи внешнего прокси могли содержать секретную часть пути `/t/{secret}`	В приложении путь редактируется (`/t/[redacted]`); вопрос редактирования пути на периметре проработан и принят	Принято, закрыто

4.2 Аутентификация, сессии и ссылка

Область	Severity	Что было	Что сделано	Статус
Перепривязка сессии	High	Метод кабинета молча перепривязывал уже активную сессию к другому профилю, а повторный вход записывал введённые токены под номер студента профиля, игнорируя введённый номер; возможна утечка чужого расписания	Запрещена перепривязка активной сессии к чужому профилю; введён сверка номера студента; токен сессии ротируется при переходе из анонимного состояния в привязанное	Исправлено
Лимит на номер студента	Medium	Заявленный лимит попыток входа на конкретный номер студента не был реализован, работал только лимит по IP; шаг одноразового кода не покрывался	Добавлен адресный бюджет попыток по номеру студента, применяемый и на шаге пароля, и на шаге одноразового кода	Исправлено
Защита от адресной блокировки	Low	Жёсткий лимит по номеру студента позволял блокировать вход чужому пользователю серией неудач с любого адреса	Ключ лимита расширен до пары «номер студента + адрес»; агрегатный бюджет по номеру переведён в мягкое замедление вместо жёсткого отказа	Исправлено
Доверие к адресу клиента	Low	Адрес клиента для ограничителя брался из первого (подделываемого) значения `X-Forwarded-For` , что позволяло обходить лимиты	Адрес принимается только от явно доверенных прокси (список CIDR, отказ по умолчанию, по умолчанию - только локальные адреса)	Исправлено
Создание сессий	Low	Предаутентификационные маршруты позволяли неограниченно создавать серверные сессии	Введён отдельный лимит на маршруты, создающие сессии, и проверка same-origin для `POST /start`	Исправлено

Область	Severity	Что было	Что сделано	Статус
Фиксация сессии	Low	При привязке анонимной сессии к профилю токен не менялся	При переходе «анонимная → привязанная» сессия перевыпускается: новый токен и новая cookie, старая удаляется	Исправлено
Cookie: префикс	Low	Cookie `rasp_sid` и `rasp_link` были host-only, но без защитного префикса; подконтрольный поддомен мог их затенять	Cookie переименованы в `__Host-rasp_sid` и `__Host-rasp_link` (требуют `Secure`, `Path=/`, без `Domain`)	Исправлено
Cookie: срок анонимной сессии	Low	Анонимной сессии выставлялся длительный `Max-Age`, не совпадавший с серверным сроком жизни	Срок анонимной cookie приведён к серверному, привязанной сессии - к её собственному сроку	Исправлено
Открытый редирект	Low	Служебный маршрут локали строил `Location` из `Referer`; путь с `//` не отсекался и мог увести на внешний хост	`Location` строится только из безопасных значений; варианты с `//` и `/\` отклоняются	Исправлено
OAuth `state`	Low	Параметр `state` был фиксированной строкой и не проверялся	Принято: поток серверный, с PKCE; риск низкий, решение зафиксировано	Принято, закрыто
Разбор JWT без подписи	Info	JWT разбирались без проверки подписи; при отсутствии числового claim номер студента мог схлопнуться в `0`	Разбор осознанно без подписи (токен валидируется вызовом API расписания); ветка с неразрешённым номером сделана фатальной	Исправлено

4.3 Секреты и персональные данные

Область	Severity	Что было	Что сделано	Статус
Промежуточное состояние 2FA	Medium	Промежуточное состояние входа (cookie-сессия провайдера входа и PKCE `code_verifier`) хранилось в базе открытым текстом, что давало материал для завершения чужого незавершённого входа при утечке дампа	Состояние переведено в зашифрованный формат `AES-256-GCM` тем же ключом, что и токены; срок жизни ограничен	Исправлено
Приватность кэша кабинета	Medium	Страницы кабинета отдавали секрет ссылки в HTML без `Cache-Control` / `Vary`, общий кэш мог отдать чужой кабинет	На `/lk*`, `/auth*` и `/session-expired` добавлены `Cache-Control: no-store` и `Vary: Cookie`	Исправлено

Область	Severity	Что было	Что сделано	Статус
Секрет в flash-cookie	Low	Промежуточная cookie административных действий хранила секрет ссылки открытым текстом	Секрет отдаётся прямо в POST-ответе с `no-store`; промежуточная cookie убрана	Исправлено
Инъекция в ICS	Low	Поле `URL:` (ссылка на онлайн-пару) не экранировалось, значение из API ИТМО с CR/LF могло сломать структуру календаря	Значение валидируется как абсолютный `http(s)`-адрес и нормализуется без CR/LF	Исправлено

4.4 Веб-заголовки и браузерная защита

Область	Severity	Что было	Что сделано	Статус
Политика безопасности контента	Low	CSP содержал только `default-src`, `img-src`, `style-src`; отсутствовали `base-uri`, `form-action`, `object-src`, `frame-ancestors`	Политика расширена до `base-uri 'self'; form-action 'self'; object-src 'none'; frame-ancestors 'none'`; `X-Frame-Options: DENY` сохранён	Исправлено
Таймауты HTTP-сервера	Low	Задавался только `ReadHeaderTimeout`; медленные тела и соединения (slowloris) не ограничивались	Добавлены `ReadTimeout`, `WriteTimeout` и `IdleTimeout`; запись вынесена осторожно из-за синхронного первого забора расписания при онбординге	Исправлено
Листинг статики	Low	`/static/` отдавал листинг каталога	Принято: информационная ценность минимальна (имена видны в HTML), path traversal при этом не работал	Принято, закрыто

4.5 Синхронизация и надёжность

Область	Severity	Что было	Что сделано	Статус
Потеря ротации refresh-токена	High	При обновлении токена у ИТМО старая пара инвалидировалась, а падение записи в базу оставляло мёртвый токен: синхронизация вставала навсегда	Добавлены ограниченные повторные попытки сохранения ротированной пары и честный сигнал с метрикой при неудаче; остаточное окно описано в рисках	Исправлено
Терминальное состояние аккаунта	Medium	Аккаунт в состоянии «нужен повторный вход» больше никогда не брался в обработку, поэтому транзиентный сбой не лечился сам	Задачи берут оба состояния; добавлено самоизлечение с периодическим повтором	Исправлено

Область	Severity	Что было	Что сделано	Статус
Паника в воркере	Medium	Паника в обработке одного аккаунта роняла весь процесс, включая веб-часть	Фоновая обработка обёрнута в `recover()` с логированием стека и исходом `panic`; процесс не падает	Исправлено
Неполный ответ источника	Medium	Частичный ответ (200 с урезанным списком) массово отменял актуальные пары; заморозка срабатывала только на полностью пустой ответ	Введён guard: подозрительно неполный ответ распознаётся и не затирает сохранённое расписание	Исправлено
Ложная заморозка сокращения	Medium	Guard сравнивал ответ с уже замороженным состоянием, поэтому законное массовое сокращение (каникулы, сессия) могло удерживать «фантомные» пары до наступления их времени	Принято как остаточный риск: защита от неполных данных может ненадолго удерживать пары при законном массовом сокращении (каникулы, сессия); поведение известно и задокументировано	Принято, закрыто
Согласованность чтения	Low	Состояние расписания читалось несколькими запросами под `READ COMMITTED`, что допускало несогласованный снапшот	Состояние читается одним SQL-снапшотом (`schedule_cache LEFT JOIN event_state`)	Исправлено
Учёт ошибок источника	Low	Коды и сообщения в ответах API расписания игнорировались	Ответы разбираются; `401` / `403` переводятся в ошибку недействительной авторизации	Исправлено
Воскрешение устаревших пар	Low	Устаревшие события могли возвращаться в ленту	Добавлен признак реконсиляции, удерживающий базовую ревизию и не допускающий воскрешения	Исправлено
Гонка кэша лент	Low	Чтение и запись файлового кэша лент могли пересечься и отдать частично записанные данные	Операции кэша сериализованы полосатым `RWMutex` по профилю	Исправлено
Регрессия `SEQUENCE`	Low	При возврате отмены после грейс-окна могла ломаться последовательность ревизий события	Надгробия отменённых событий после грейса скрыты из рендера, но держат базовую ревизию	Исправлено
Жизненный цикл процесса	High	Бюджет остановки контейнера был меньше времени плавного завершения приложения; проверка работоспособности не смотрела на базу	Согласованы `stop_grace_period` и завершение приложения; маршрутизация переведена на `/readyz`, проверка работоспособности - по нему же	Исправлено

Область	Severity	Что было	Что сделано	Статус
Реконсиляция событий	Info	Требовалось привести изменения расписания к канонической форме календаря	События реконсилируются по RFC 5545: `SEQUENCE`, `STATUS:CANCELLED`, грейс-окно отмены, надгробия	Исправлено

4.6 Кэши и приватность

Область	Severity	Что было	Что сделано	Статус
Срок жизни и объём кэша	Medium	Файловый кэш лент не имел ограничения по сроку жизни и объёму, не было вытеснения; удаление профиля администратором не инвалидировало кэш	Добавлены ограничение по сроку жизни, квота с вытеснением по давности и ленивой очисткой; кэш инвалидируется при административном удалении и обновлении	Исправлено
Гонка инвалидации	Low	Уже начатая отрисовка после отзыва могла повторно записать данные профиля в кэш	Инвалидация согласована с отрисовкой; остаточное окно ограничено сроком жизни кэша, секрета в файле нет	Принято, закрыто
Кэш на один экземпляр	Medium	Лимитеры в памяти и файловый кэш работают в рамках одного экземпляра и сбрасываются при перезапуске; при нескольких репликах бюджеты складываются	Принято для текущего масштаба: кэш каждого экземпляра свой, бюджеты при масштабировании умножаются; поведение задокументировано	Принято, закрыто

4.7 Эксплуатация и наблюдаемость

Область	Severity	Что было	Что сделано	Статус	
Резервное копирование	Critical	Бэкапов не было; скрипт `pg_dump \	gzip `без` pipefail` мог молча создать битый дамп; не было offsite, WAL/PITR и отката миграций	Скрипт переписан (custom-format дамп, проверка через `pg_restore --list`, атомарная запись, offsite, ротация по числу и сроку); добавлены проверка свежести и учебное восстановление; RPO/RTO и процедура отката задокументированы	Исправлено

Область	Severity	Что было	Что сделано	Статус
Соответствие деплоя	High	Отслеживаемый конфигурационный файл описывал сборку из исходников, тогда как в прод выкладывался готовый образ; процедура отката не была определена	Конфигурация приведена к деплою готового образа с `pull_policy: never`; процедуры деплоя и отката описаны в runbook	Исправлено
Наблюдаемость	High	Не было метрик и оповещений; канареечная проверка не стояла на расписании	Добавлен `GET /metrics` в формате Prometheus (на стандартной библиотеке) на отдельном внутреннем интерфейсе: HTTP, состояние воркера, метрики синхронизации. Внешний сбор метрик, алерты и канарейка на расписании приняты как эксплуатационный долг и закрыты	Принято, закрыто
Ограничения ресурсов	High	Не были заданы лимиты памяти и процессора; кэш в памяти мог вытеснить базу и привести к её падению по OOM	Заданы лимиты памяти и процессора для приложения и базы, тюнинг базы, ограничение пула соединений и ротация логов	Исправлено
Артефакты сборки	Medium	Использовался изменяемый тег без метаданных сборки	Добавлен публичный `GET /version` и метки образа	Исправлено
Непрерывные проверки	Medium	Не было автоматических сборок, сканирования зависимостей и образа	Принято: отложено до переезда на площадку; текущий уровень обеспечивают ручные прогоны и сканер зависимостей	Принято, закрыто

Область	Severity	Что было	Что сделано	Статус
Журналы	Medium	Ротация логов не была настроена; логировался каждый опрос ленты	Ротация логов добавлена, уровень шума на частых запросах снижен; редактирование секрета в логах периметра принято как эксплуатационный долг и закрыто	Принято, закрыто
База данных	Medium	Не было `statement_timeout` и метрик пула; тяжёлые агрегаты держали соединение	Тюнинг базы добавлен; `statement_timeout` и метрики пула приняты как технический долг и закрыты	Принято, закрыто
Секреты эксплуатации	Medium	В конфигурации оставался небезопасный дефолт пароля базы; секреты задавались переменными окружения	Принято: секреты прод-контура задаются вне репозитория; дефолт относится к локальному контуру разработки	Принято, закрыто
Мониторинг TLS/CA	Medium	Продление сертификатов было ручным и без мониторинга; промежуточный сертификат Минцифры имеет срок действия	Добавлена проверка сертификатов по расписанию; срок промежуточного сертификата остаётся остаточным риском	Исправлено
Скользящий срок сессии	Low	Срок сессии продлевался записью в базу на каждый запрос; поле последней активности не обновлялось	Принято: запись на каждый запрос оставлена; поведение зафиксировано	Принято, закрыто
Единая точка отказа	Low	Приложение и база размещены на одном сервере без горячего резерва	Принято для текущего масштаба; риски и процедуры восстановления задокументированы	Принято, закрыто

Область	Severity	Что было	Что сделано	Статус
Видимость залипших аккаунтов	Low	Аккаунты, требующие повторного входа, не были видны оператору	Добавлено самоизлечение таких аккаунтов; состояние видно по метрике; внешний алерт настраивается в эксплуатационном контуре	Исправлено
Пароль в dev-контуре	Low	Локальная конфигурация публиковала базу на все интерфейсы с тривиальным паролем	Принято: относится к локальному контуру разработки, в прод не используется	Принято, закрыто

4.8 Протоколы CalDAV и ICS

Область	Severity	Что было	Что сделано	Статус
`METHOD:PUBLISH` в CalDAV	High	`METHOD:PUBLISH` попадал в каждый объект CalDAV-коллекции, что противоречит RFC 4791 (MUST NOT)	`METHOD:PUBLISH` оставлен только в подписной ленте, не в объектах CalDAV	Исправлено
Реклама `sync-collection`	Medium	Возможность синхронизации была реализована, но отсутствовала в `supported-report-set` (RFC 6578)	Возможность добавлена в набор поддерживаемых отчётов	Исправлено
Удаления в `sync-collection`	Medium	Синхронизация не сообщала об удалениях, поэтому клиент навсегда хранил удалённые события (RFC 6578)	Добавлены надгробия (404) для удалённых объектов	Исправлено
`PROPFIND` и свойства	Medium	Запрос игнорировал запрошенные свойства и не выдавал `404` propstat (RFC 4918)	Разбираются `prop`, `propname` и `allprop`, возвращается корректный `404` propstat	Исправлено
`Depth` в WebDAV	Medium	`Depth: infinity` и отсутствующий `Depth` трактовались как `1` (RFC 4918)	Поддержаны `Depth: 0`, `1` и `infinity`	Исправлено
`calendar-query` и `time-range`	Medium	Отчёт игнорировал фильтр `time-range` (RFC 4791)	Фильтр `time-range` применяется; отдаётся только запрошенное окно	Исправлено
Неизвестный `REPORT`	Low	Неизвестный отчёт возвращал `207` вместо `403` с `DAV:supported-report`	Возвращается `403` и корректный `DAV:supported-report`	Исправлено
Fallback refresh-TTL	Low	Резервное значение срока действия токена было занижено	Резервное значение приведено к корректному порядку	Исправлено

Область	Severity	Что было	Что сделано	Статус
Методы на машинных ресурсах	Low	`POST` / `OPTIONS` на ленте давали `404` без заголовка `Allow`	Возвращается `405` с `Allow`	Исправлено

4.9 Доступность и удобство

Область	Severity	Что было	Что сделано	Статус
Необратимые действия без JS	High	Без JavaScript «Отозвать» и «Перевыпустить» срабатывали без подтверждения: одно касание - необратимое действие	Добавлено двухшаговое подтверждение без JS (серверные confirm-страницы с CSRF)	Исправлено
Состояние при сбое синхронизации	High	Сбойная синхронизация показывалась зелёным «подписка активна», хотя данные устарели	Кабинет показывает честное состояние ошибки и предлагает действия	Исправлено
Копирование ссылки без JS	Medium	Без JavaScript нельзя было скопировать ссылку подписки	Без JavaScript ссылка показывается полным текстом (её можно выделить и скопировать вручную); со скриптом она подменяется на маску с кнопкой копирования	Исправлено
Контраст фокуса	Medium	Индикатор фокуса имел контраст около 1.5:1, ниже порога WCAG 1.4.11	Индикатор фокуса сделан контрастным	Исправлено
Единственный CTA	Medium	Основной призыв к действию вёл только в Apple Календарь и не работал на других платформах	Призыв сделан нейтральным для разных календарей	Исправлено
Лимит и общий NAT	Medium	Общий лимит по IP бьёт по пользователям за одним внешним адресом (кампус, офис, мобильный оператор)	Принято: лимит по IP оставлен как антиабузный; добавлен отдельный лимит по профилю	Принято, закрыто
Контакт на `/about`	Medium	На странице «О сервисе», где просят пароль ИТМО, не было способа связи	Принято: решение о размещении контакта оставлено владельцу сервиса	Принято, закрыто
Метаданные ленты	Low	В ленте не было `REFRESH-INTERVAL` и `X-PUBLISHED-TTL`, название календаря было только на русском	Добавлены метаданные периодичности (`REFRESH-INTERVAL` , `X-PUBLISHED-TTL`); название календаря сделано двуязычным (`X-WR-CALNAME`); полная локализация отложена	Исправлено

Область	Severity	Что было	Что сделано	Статус
Промо-строка в описании событий	Low	Промо-строка в DESCRIPTION каждого события (шум)	Принято: промо оставлено и в описании событий, и в описании календаря (X-WR-CALDESC) как осознанный размен ради охвата; карточка описания календаря видна не во всех клиентах	Принято, закрыто
Области нажатия	Low	Области нажатия аккордеонов были меньше рекомендуемых	Увеличены до рекомендуемых размеров	Исправлено
Игнорируемый офсет напоминаний	Low	В одном из режимов напоминаний активное смещение не применялось	Неоднозначное поведение устранено	Исправлено
Экран OTP без 2FA	Low	Экран одноразового кода открывался по прямому URL даже без запрошенного второго фактора	Экран показывается только при реально ожидающем шаге	Исправлено
VALARM в Google	Low	Google Календарь не показывает напоминания из подписок по URL	Принято: это ограничение Google, отмечено в интерфейсе и документации	Принято, закрыто
Микрокопирайт	Low	Расхождения в текстах («ни уведомлений» против раздела «Уведомления») и знак `my.itmo` в hero	Тексты приведены в порядок	Исправлено

4.10 Зависимости и цепочка поставки

Область	Severity	Что было	Что сделано	Статус
Уязвимые зависимости	High	Сканер находил достижимые уязвимости в стандартной библиотеке и в `golang.org/x/text`	Toolchain и зависимости обновлены; `govulncheck` даёт 0 известных уязвимостей	Исправлено
Закрепление базовых образов	Low	Базовые образы закреплены по тегам, а не по контрольным суммам	Принято: закрепление по дайджестам отложено как технический долг	Принято, закрыто

5. Остаточные принятые риски

Ниже - риски, сознательно принятые и закрытые с компенсирующими мерами. Открытых пунктов нет.

- **Строгий режим HSTS не включён** на текущем периметре; компенсируется обязательным HTTPS-редиректом.
- **Ограничители частоты и файловые кэши работают в рамках одного экземпляра.** При масштабировании на несколько экземпляров бюджеты складываются, а кэш у каждого свой; для текущего масштаба это приемлемо.
- **Окно ротации refresh-токена.** Теоретическая потеря обновлённого токена при редком сбое сохранения сокращена ограниченными повторными попытками, но полностью не устранима без внешнего хранилища; аккаунт самовосстанавливается.

- **Неполный ответ и реальное сокращение расписания.** Защита от неполных данных может ненадолго удерживать пары при законном массовом сокращении до наступления их времени; поведение известно и задокументировано.
- **Неофициальность.** Сервис использует неофициальный вход в ИТМО; источник может измениться. Взаимодействие с ним изолировано, покрыто тестами, есть периодическая проверка работоспособности.
- **Двухфакторный вход.** Ветка с одноразовым кодом покрыта тестами, но на живом аккаунте с принудительным вторым фактором не проверялась.
- **Срок промежуточного сертификата Минцифры** отслеживается мониторингом; обновление требует пересборки образа.
- **Резервные копии, вывозимые за пределы доверенного контура,** рекомендуется дополнительно шифровать.
- **Холодный старт кэшей.** После перезапуска кэш пуст, первые запросы идут более дорогим путём; это временно и безопасно для пользователя.
- **Единый сервер.** Приложение и база на одном сервере без горячего резерва.

6. Вердикт

Приложение: защищённость выше среднего для неофициального проекта. Критических и высоких уязвимостей в коде не обнаружено; все находки проверок закрыты - исправлены либо осознанно приняты как риск с компенсирующими мерами. Блокеров для эксплуатации нет. Основные остаточные риски носят эксплуатационный и периметровый характер и не связаны с приложением.

Обзор носит характер **внутренней самооценки** и не заменяет независимый внешний аудит периметра, инфраструктуры и сторонних сервисов. Открытых пунктов на момент публикации нет.

Внутренний обзор (self-assessment), не независимый аудит. Неофициальный сервис, не связан с Университетом ИТМО. Названия и товарные знаки принадлежат их владельцам.